



Solution Guide: Types of Penetration Testing

In this activity, you are a managing consultant at a penetration testing firm, GoodCorp. You've recently been asked to conduct several penetration tests. You have reviewed the scenarios around each request to determine what type of penetration test is required and whether it's legal.

Instructions

Review each scenario carefully and determine what type of penetration test approach is applicable (full view, partial view, no view) and if the scenario is legal. If the scenario's legality is questionable, determine what would be required to make the scenario legal.

Scenario Questions

1. A business hires you to perform a penetration test. Credentials will be provided to you as long as you do not share them with anyone outside the business. Before starting the assessment, the business makes you sign a non-disclosure agreement (NDA) and covers the rules of engagement (ROE).
 - Legal
 - Partial view
2. A friend verbally asks you to hack his home network and gives you his public router's IP address.
 - Illegal
 - Verbal consent cannot be proven if the assessor is indicted.
 - Black box
3. You are on a random shopping website and discover a potential vulnerability. Using your recent knowledge from class, you attempt to validate whether the website is vulnerable to an attack.
 - Illegal
 - Knowingly performing any type of security assessment without consent is illegal.
 - Black box

4. A local government hires you to perform a penetration test on its internal network, giving you full access to all its network diagrams and device IP lists and supplying you with administrative credentials. A contract is signed by all appropriate parties.
 - Legal
 - Full view
5. After negotiating a contract and signing all legal forms, an enterprise business hires you to perform a penetration test. It supplies you with a domain name that is in scope and a two-month assessment time.
 - Legal
 - No view
6. A family member asks you to assess the security of their home network. You bring your laptop, connect to their WiFi, and begin the assessment with port scans.
 - Legal
 - No view
7. A business hires you to perform an assessment and sends over a contract that states all company-owned hardware is within scope and provides you with a list of assets. When searching the public IP addresses of the assets from the provided lists, you determine they are hosted within Microsoft's cloud platform, Azure.
 - Illegal
 - The contract explicitly states that "company-owned hardware" is in scope. Azure's cloud platform is not considered the company's own hardware, so the contract must also explicitly state that it's within scope for this to be legal.
 - Partial view
8. A medium-sized business hires you to perform a penetration test and supplies you with credentials and scope. The contract is almost finalized, but the manager insists that you start the assessment now to avoid lapsing into the next fiscal year.
 - Illegal
 - Contracts must be finalized before any assessment work may begin.
 - Full view